

- f. Communication lines with other business units (e.g., loan review, credit risk management, line of business quality assurance, and internal audit).
 - g. Credit or operating losses primarily attributable (or thought to be attributable) to IT (e.g., system problems, fraud occurring due to poor controls, and improperly implemented changes to systems).
 - h. Changes to internal business processes.
 - i. Internal reorganizations.
4. Determine the complexity of the institution's information security environment.
 - a. Determine the degree of reliance on service providers for information processing and technology support, including security operation management.
 - b. Identify unique products and services and any required third-party access requirements.
 - c. Determine the extent of network connectivity internally and externally and the boundaries and functions of security domains.
 - d. Identify the systems that have recently undergone significant change, such as new hardware, software, configuration, and connectivity. Correlate the changed systems with the business processes they support, the extent of customer data available to those processes, and the effect of those changes on institution operations.

Objective 2: Determine whether management promotes effective governance of the information security program through a strong information security culture, defined information security responsibilities and accountability, and adequate resources to support the program.

1. Determine whether the institution has a culture that contributes to the effectiveness of the information security program.
 - a. Determine whether the institution's board and management understand and support information security and provide appropriate resources for the implementation of an effective security program.
 - b. Determine whether the information security program is integrated with the institution's lines of business, support functions, and management of third parties.
 - c. Review for indicators of an effective information security culture (e.g., method of introducing new business initiatives and manner in which the institution holds lines of business and employees accountable for promoting information security).
2. Determine whether the board, or a committee of the board, is responsible for overseeing the development, implementation, and maintenance of the institution's information security program.
3. Determine whether the board holds management accountable for the following:
 - a. Central oversight and coordination.
 - b. Assignment of responsibility.
 - c. Support of the information security program.

- d. Effectiveness of the information security program.
4. Determine whether the board approves a written information security program and receives a report on the effectiveness of the information security program at least annually. Determine whether the report to the board describes the overall status of the information security program and discusses material matters related to the program such as the following:
 - a. Risk assessment process, including threat identification and assessment.
 - b. Risk management and control decisions.
 - c. Service provider arrangements.
 - d. Results of security operations activities and summaries of assurance reports.
 - e. Security breaches or violations and management's responses.
 - f. Recommendations for changes or updates to the information security program.
5. Determine whether management responsibilities are appropriate and include the following:
 - a. Implementation of the information security program by clearly communicating responsibilities and holding appropriate individuals accountable for carrying out these responsibilities.
 - b. Establishment of appropriate policies, standards, and procedures to support the information security program.
 - c. Participation in assessing the effect of security threats or incidents on the institution and its business lines and processes.
 - d. Delineation of clear lines of responsibility and communication of accountability for information security.
 - e. Adherence to risk thresholds established by the board relating to information security threats or incidents, including those relating to cybersecurity.
 - f. Oversight of risk mitigation activities that support the information security program.
 - g. Establishment of appropriate segregation of duties.
 - h. Coordination of both information and physical security.
 - i. Integration of security controls throughout the institution.
 - j. Protection of data consistently throughout the institution.
 - k. Definition of the information security responsibilities of third parties.
 - l. Facilitation of annual information security and awareness training and ongoing security-related communications to employees.
6. Determine whether management has designated one or more individuals as an information security officer and determine appropriateness of the reporting line.
7. Determine whether security officers and employees know, understand, and are accountable for fulfilling their security responsibilities.

8. Determine the adequacy of audit coverage and reporting of the information security program by reviewing appropriate audit reports and board or audit committee minutes. (For further questions, refer to the *IT Handbook's* "Audit" booklet examination procedures.)⁶³
9. Determine whether the board provides adequate funding to develop and implement a successful information security function. Review whether the institution has the following:
 - a. Appropriate staff with the necessary skills to meet the institution's technical and managerial needs.
 - b. Personnel with knowledge of technology standards, practices, and risk methodologies.
 - c. Training to prepare staff for their short- and long-term security responsibilities.
 - d. Oversight of third parties when they supplement an institution's technical and managerial capabilities.
10. Determine whether management has adequately incorporated information security into its overall ITRM process. (For further questions, refer to the *IT Handbook's* "Management" booklet examination procedures.)⁶⁴

Objective 3: Determine whether management of the information security program is appropriate and supports the institution's ITRM process, integrates with lines of business and support functions, and integrates third-party service provider activities with the information security program.

1. Determine whether the institution has an effective information security program that supports the ITRM process. Review whether the program includes the following:
 - a. Identification of threats and risks.
 - b. Measurement of risks.
 - c. Implementation of risk mitigation.
 - d. Monitoring and reporting of risks.
 - e. Methods to assess the program's effectiveness.
2. Determine whether management appropriately integrates the information security program across the institution's lines of business and support functions. Review whether management has the following:
 - a. Security policies, standards, and procedures that are designed to support and to align with the policies in the lines of business.
 - b. Incident response programs that include all affected lines of business and support units.
 - c. Common awareness and enforcement mechanisms between lines of business and information security.
 - d. Visibility to assess the likelihood of threats and potential damage to the institution.
 - e. The ability to identify and implement controls over the root causes of an incident.

⁶³ See the *IT Handbook's* "Audit" booklet examination procedures.

⁶⁴ See the *IT Handbook's* "Management" booklet examination procedures.

3. If the institution outsources activities to a third-party service provider, determine whether management integrates those activities with the information security program. Verify that the third-party management program evidences expectations that align with the institution's information security program.

Objective 4: As part of the information security program, determine whether management has established risk identification processes.

1. Determine whether management effectively identifies threats and vulnerabilities continuously.
2. Determine whether the risk identification process produces manageable groupings of information security threats, including cybersecurity threats. Review whether management has the following:
 - a. A threat assessment to help focus the risk identification efforts.
 - b. A method or taxonomy for categorizing threats, sources, and vulnerabilities.
 - c. A process to determine the institution's information security risk profile.
 - d. A validation of the risk identification process through audits, self-assessments, penetration tests, and vulnerability assessments.
 - e. A validation through audits, self-assessments, penetration tests, and vulnerability assessments that risk decisions are informed by appropriate identification and analysis of threats and other potential causes of loss.
3. Determine whether management has a means to collect data on potential threats to identify information security risks. Determine whether management uses threat modeling (e.g., development of attack trees) to assist in identifying and quantifying risk and in better understanding the nature, frequency, and sophistication of threats.
4. Determine whether management has continuous, established routines to identify and assess vulnerabilities. Determine whether management has processes to receive vulnerability information disclosed by external individuals or groups, such as security or vulnerability researchers.
5. Determine whether management adjusts the information security program for institutional changes and changes in legislation, regulation, regulatory policy, guidance, and industry practices. Review whether management has processes to do the following:
 - a. Maintain awareness of new legal and regulatory requirements or changes to industry practices.
 - b. Update the information security program to reflect changes.
 - c. Report changes of the information security program to the board.

Objective 5: Determine whether management measures the risk to guide its recommendations for and use of mitigating controls.

1. Determine whether management uses tools to perform threat analysis and analyzes information security events to help do the following:
 - a. Map threats and vulnerabilities.
 - b. Incorporate legal and regulatory requirements.
 - c. Improve consistency in risk measurement.
 - d. Highlight potential areas for mitigation.
 - e. Allow comparisons among different threats, events, and potential mitigating controls.

Objective 6: Determine whether management effectively implements controls to mitigate identified risk.

1. Determine whether policies, standards, and procedures are of sufficient scope and depth to guide information security-related decisions. Review whether policies, standards, and procedures have the following characteristics:
 - a. Are appropriately implemented and enforced.
 - b. Delineate areas of responsibility.
 - c. Are communicated in a clear and understandable manner.
 - d. Are reviewed and agreed to by employees.
 - e. Are appropriately flexible to address changes in the environment.
2. Determine whether the information security policy is annually reviewed and approved by the board.
3. Determine whether the institution continually assesses the capability of technology needed to sustain an appropriate level of information security based on the size, complexity, and risk appetite of the institution.
4. Determine whether management implements an integrated control system characterized by the use of different control types that mitigates identified risks. Review whether management does the following:
 - a. Implements a layered control system using different controls at different points in a transaction process.
 - b. Uses controls of different classifications, including preventive, detective, and corrective.
 - c. Verifies that compensating controls are used appropriately to compensate for weaknesses with the system or process.
5. Determine whether management implements controls that appropriately align security with the nature of the institution's operations and strategic direction. Specifically, review whether management does the following:

- a. Implements controls based on the institution's risk assessment to mitigate risk from information security threats and vulnerabilities, such as interconnectivity risk.
 - b. Evaluates whether the institution has the necessary resources, personnel training, and testing to maximize the effectiveness of the controls.
 - c. Reviews and improves or updates the security controls, where necessary.
6. Determine whether management effectively maintains an inventory(ies) of hardware, software, information, and connections. Review whether management does the following:
 - a. Identifies assets that require protection, such as those that store, transmit, or process sensitive customer information, or trade secrets.
 - b. Classifies assets appropriately.
 - c. Uses the classification to determine the sensitivity and criticality of assets.
 - d. Uses the classification to implement controls required to safeguard the institution's assets.
 - e. Updates the inventory(ies) appropriately.
7. Determine whether management comprehensively and effectively identifies, measures, mitigates, monitors, and reports interconnectivity risk. Review whether management does the following:
 - a. Identifies connections with third parties.
 - b. Identifies access points and connection types that pose risk.
 - c. Identifies connections between and access across low-risk and high-risk systems.
 - d. Measures the risk associated with connections with third parties with remote access.
 - e. Implements and assesses the adequacy of appropriate controls to ensure the security of connections.
 - f. Monitors and reports on the institution's interconnectivity risk.
8. Determine whether management effectively mitigates risks posed by users. Review whether management does the following:
 - a. Develops and maintains a culture that fosters responsible and controlled access for users.
 - b. Establishes and effectively administers appropriate security screening in IT hiring practices.
 - c. Establishes and appropriately administers a user access program for physical and logical access.
 - d. Employs appropriate segregation of duties.
 - e. Obtains agreements from employees, contractors, and service providers covering confidentiality, nondisclosure, and authorized use.
 - f. Provides training to support awareness and policy compliance.
9. Determine whether management applies appropriate physical security controls to protect its premises and more sensitive areas, such as its data center(s).

10. Determine whether management secures access to its computer networks through multiple layers of access controls. Review whether management does the following:
 - a. Establishes zones (e.g., trusted and untrusted) according to risk with appropriate access requirements within and between each zone.
 - b. Maintains accurate network diagrams and data flow charts.
 - c. Implements appropriate controls over wired and wireless networks.
11. Determine whether management has a process to introduce changes to the environment (e.g., configuration management of IT systems and applications, hardening of systems and applications, use of standard builds, and patch management) in a controlled manner. Determine whether management does the following:
 - a. Maintains procedures to guide the process of introducing changes to the environment.
 - b. Defines change requirements.
 - c. Restricts changes to authorized users.
 - d. Reviews the potential impact changes have on security controls.
 - e. Identifies all system components affected by the changes.
 - f. Develops test scripts and implementation plans.
 - g. Performs necessary tests of all changes to the environment (e.g., systems testing, integration testing, functional testing, user acceptance testing, and security testing).
 - h. Defines rollback procedures in the event of unintended or negative consequences with the introduced changes.
 - i. Verifies the application or system owner has authorized changes in advance.
 - j. Maintains strict version control of all software updates.
 - k. Validates that new hardware complies with institution policies and guidelines.
 - l. Verifies network devices are properly configured and function appropriately within the environment
 - m. Maintains an audit trail of all changes.
12. Determine whether appropriate processes exist for configuration management (managing and controlling configurations of systems, applications, and other technology).
13. Determine whether management has processes to harden applications and systems (e.g., installing minimum services, installing necessary patches, configuring appropriate security settings, enforcing principle of least privilege, changing default passwords, and enabling logging).
14. Determine whether management uses standard builds, allowing one documented configuration to be applied to multiple computers in a controlled manner, to create hardware and software inventories, update or patch systems, restore systems, investigate anomalies, and audit configurations.
15. Determine whether management has a process to update and patch operating systems, network devices, and software applications, including internally developed software provided

to customers, for newly discovered vulnerabilities. Review whether patch management processes include the following:

- a. An effective monitoring process that identifies the availability of software patches.
- b. A process to evaluate the patches against the threat and network environment.
- c. A prioritization process to determine which patches to apply across classes of computers and applications.
- d. A process for obtaining, testing, and securely installing the patches.
- e. An exception process, with appropriate documentation, for patches that an institution decides to delay or not apply.
- f. A process to ensure that all patches installed in the production environment are also installed in the disaster recovery environment.
- g. A documentation process to ensure the institution's information assets and technology inventory and disaster recovery plans are updated as appropriate when patches are applied.
- h. Actions to ensure that patches do not compromise the security of the institution's systems.

16. Determine whether management plans for the life cycles of the institution's systems, eventual end of life, and any corresponding business impacts. Review whether the institution's life cycle management includes the following:

- a. Maintaining inventories of systems and applications.
- b. Adhering to an approved end-of-life or sunset policy for older systems.
- c. Tracking changes made to the systems and applications, availability of updates, and the planned end of support by the vendor.
- d. Planning for the update or replacement of systems nearing obsolescence.
- e. Outlining procedures for the secure destruction or wiping of hard drives being returned to vendors or donated to prevent the inadvertent disclosure of sensitive information.

17. Determine whether management has implemented defense-in-depth to protect, detect, and respond to malware.

18. Determine whether management maintains policies and effectively controls and protects access to and transmission of information to avoid loss or damage. Review whether management does the following:

- a. Requires secure storage of all types of sensitive information, whether on computer systems, portable devices, physical media, or hard-copy documents.
- b. Establishes controls to limit access to data.
- c. Requires appropriate controls over data stored in a cloud environment.
- d. Implements appropriate controls over the electronic transmission of information or, if appropriate safeguards are unavailable, restricts the type of information that can be transmitted.
- e. Has appropriate disposal procedures for both paper-based and electronic information.

- f. Maintains the security of physical media, including backup tapes, containing sensitive information while in transit, including to off-site storage, or when shared with third parties.
 - g. Has policies restricting the use of unsanctioned or unapproved IT resources (e.g., online storage services, unapproved mobile device applications, and unapproved devices).
- 19. Determine whether management identifies factors that may increase risk from supply chain attacks and responds with appropriate risk mitigation. Review whether management implements the following as appropriate:
 - a. Purchases are made only through reputable sellers.
 - b. Purchases are made through a third party to shield the institution's identity.
 - c. Hardware is reviewed for anomalies.
 - d. Software is reviewed through both automated software testing and code reviews.
 - e. Reliability of the items purchased is regularly reviewed post-implementation.
- 20. Determine whether management has an effective process to administer logical security access rights for the network, operating systems, applications, databases, and network devices. Review whether management has the following:
 - a. An enrollment process to add new users to the system.
 - b. An authorization process to add, delete, or modify authorized user access to operating systems, applications, directories, files, and specific types of information.
 - c. A monitoring process to oversee and manage the access rights granted to each user on the system.
 - d. A process to control privileged access.
 - e. A process to change or disable default user accounts and passwords.
- 21. As part of management's process to secure the operating system and all system components, determine whether management does the following:
 - a. Limits the number of employees with access to operating system and system utilities and grants only the minimum level of access required to perform job responsibilities.
 - b. Restricts and logs access to and activity on operating system parameters, system utilities (especially those with data-altering capabilities), and sensitive system resources (including files, programs, and processes), and supplements with additional security software, as necessary.
 - c. Restricts operating system access to specific terminals in physically secure and monitored locations.
 - d. Secures or removes external drives and portable media from system consoles, terminals, or PCs running terminal emulations, residing outside of physically secure locations.
 - e. Prohibits remote access to operating system and system utilities, where feasible, and, at a minimum, requires strong authentication and encrypted sessions before allowing such remote access.
 - f. Filters and reviews logs for potential security events and provides adequate reports and alerts.

- g. Independently monitors operating system access by user, terminal, date, and time of access.
22. Determine whether management controls access to applications. Review whether management does the following:
- a. Implements a robust authentication method consistent with the criticality and sensitivity of the application.
 - b. Manages application access rights by using group profiles.
 - c. Periodically reviews and approves the application access assigned to users for appropriateness.
 - d. Communicates and enforces the responsibilities of programmers, security administrators, and application owners in maintaining effective application access control.
 - e. Sets time-of-day or terminal limitations for some applications or for more sensitive functions within an application.
 - f. Logs access and events, defines alerts for significant events, and develops processes to monitor and respond to anomalies and alerts.
23. Determine whether management has policies and procedures to ensure that remote access by employees, whether using institution or personally owned devices, is provided in a safe and sound manner. Review whether management does the following:
- a. Provides remote access in a safe and sound manner.
 - b. Implements the controls necessary to offer remote access securely (e.g., disables unnecessary remote access, obtains approvals for and performs audits of remote access, maintains robust configurations, enables logging and monitoring, secures devices, restricts remote access during specific times, controls applications, enables strong authentication, and uses encryption).
24. Determine whether management effectively controls employees' use of remote devices. Review whether management does the following:
- a. Implements controls over institution owned and personally owned devices used by employees to access the network (e.g., disallows remote access without business justification, requires management approval, reviews remote access approvals, restricts access to authorized network areas, logs remote access, implements robust authentication, uses encryption, and uses application white-listing).
 - b. Implements controls over remote devices provided by the institution (e.g., securely configures remote access devices, protects devices against malware, patches and updates software, encrypts sensitive data, implements secure containers, audits device access, uses remote disable and wipe capabilities, and uses geolocation).
 - c. Uses an effective method to ensure personally owned devices meet defined institution security standards (e.g., such as operating system version, patch levels, and anti-malware solutions).